

IP Security

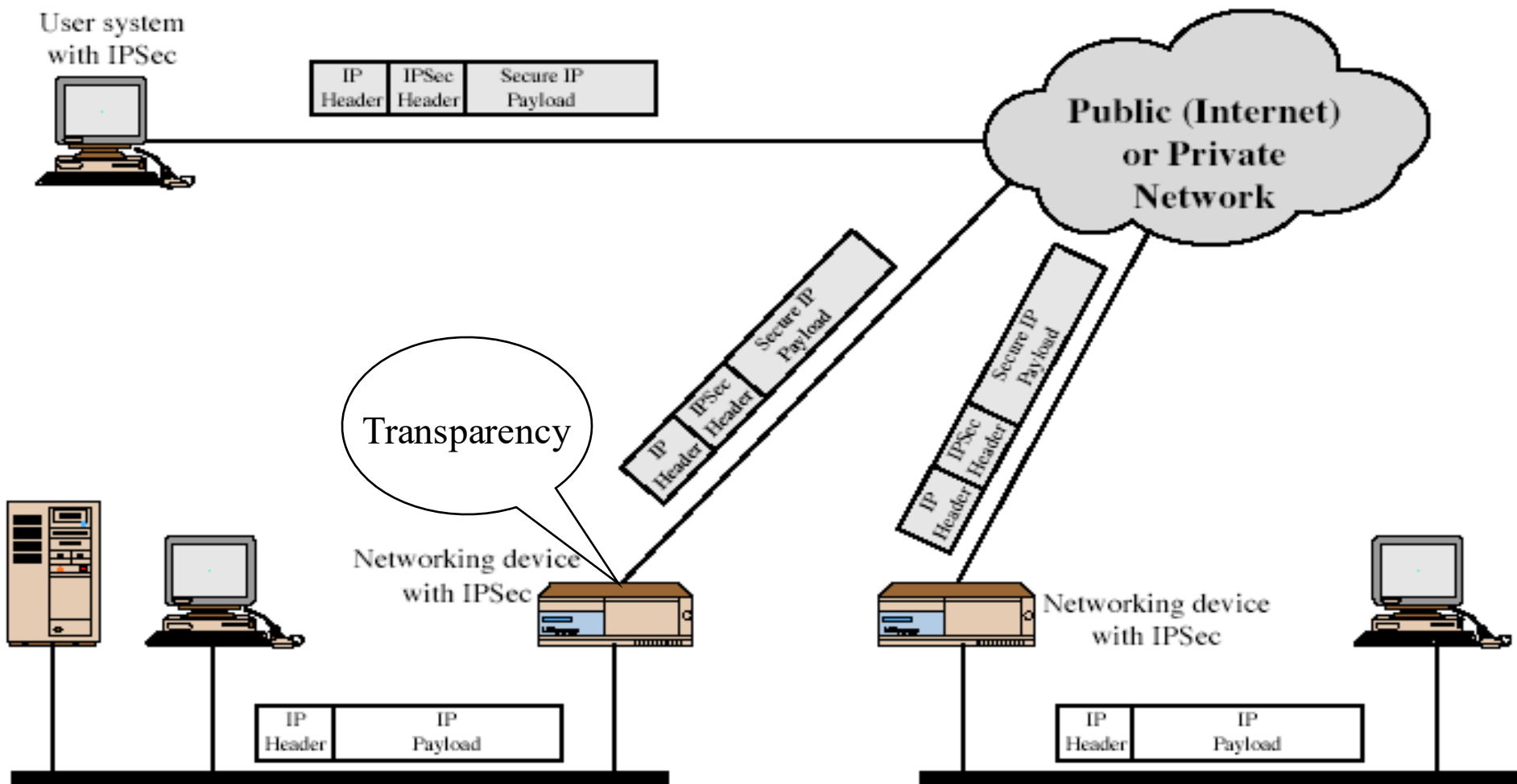
IP Security

- ❑ Have a range of application specific security mechanisms
 - ❑ eg. S/MIME, PGP, Kerberos, SSL/HTTPS
- ❑ However there are security concerns that cut across protocol layers
- ❑ Would like security implemented by the network for all applications

IPSec

- ❑ General IP Security mechanisms
- ❑ Provides
 - ❑ authentication
 - ❑ confidentiality
 - ❑ key management
- ❑ Applicable to use over LANs, across public & private WANs, & for the Internet

IPSec Uses



VPN

- ❑ Application-level VPN
 - ❑ E.g., tunnel through ssh
 - ❑ Analogous to app-level gateways
- ❑ IPSec-based VPN
 - ❑ Analogous to packet-filtering firewalls

Benefits of IPSec

- ❑ In a firewall/router, provides strong security to all traffic crossing the perimeter
- ❑ Is below transport layer, hence transparent to applications
- ❑ Can be transparent to end users
- ❑ Can provide security for individual even mobile users
- ❑ Secures routing architecture

IP Security Architecture

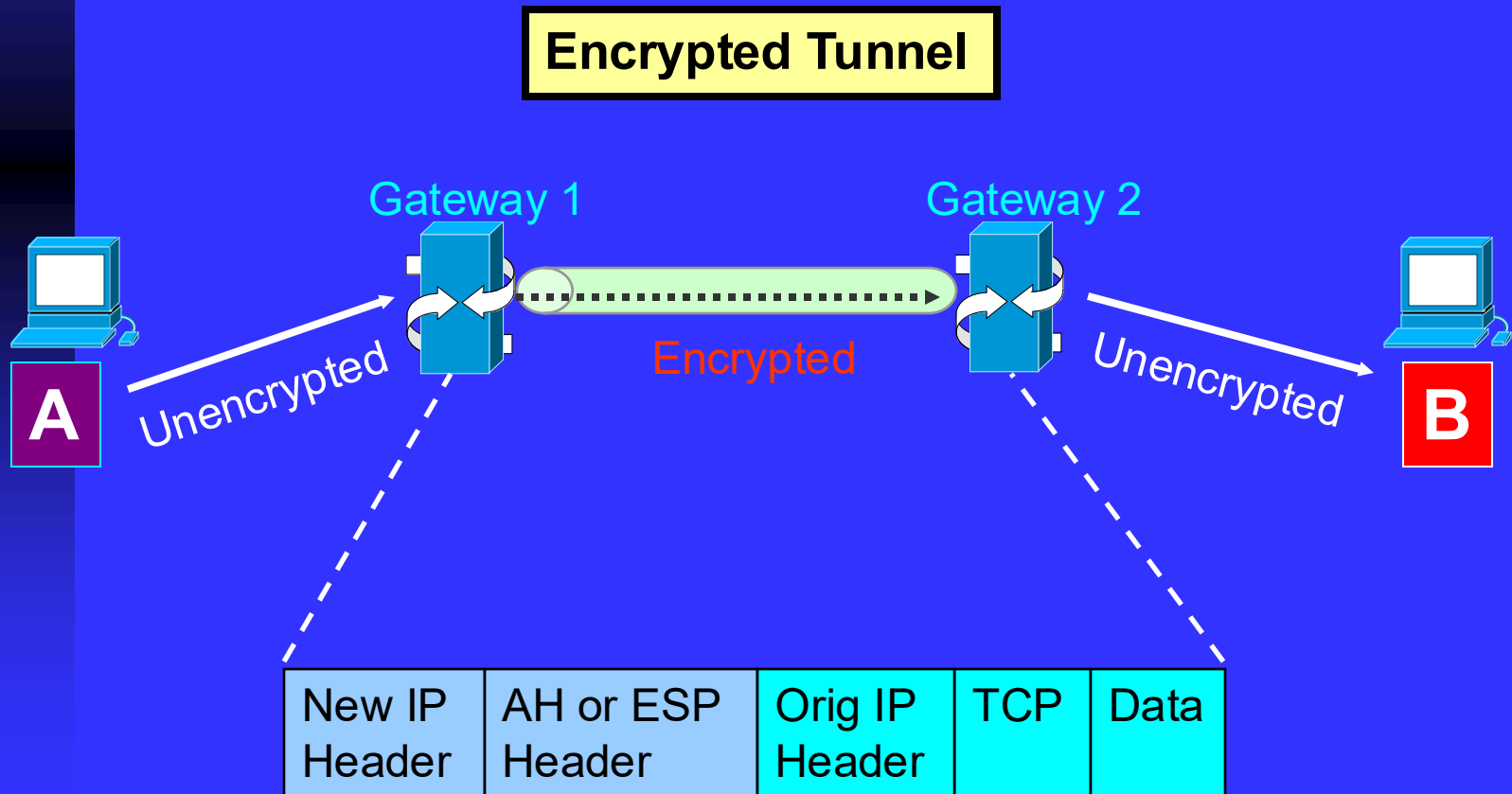
- ❑ Specification is quite complex
- ❑ Defined in numerous RFC's
 - ❑ incl. RFC 2401/2402/2406/2408
 - ❑ many others, grouped by category
- ❑ Mandatory in IPv6, optional in IPv4
- ❑ Have two security header extensions:
 - ❑ Authentication Header (AH)
 - ❑ Encapsulating Security Payload (ESP)

Architecture & Concepts

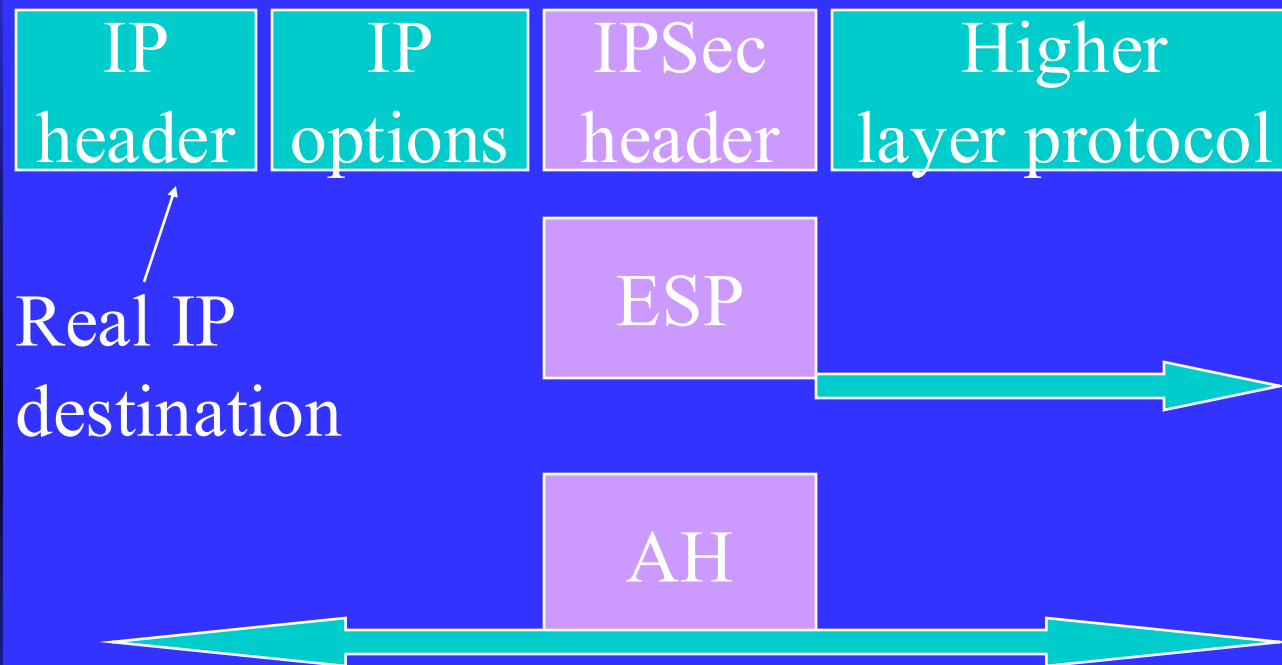
- ❑ Tunnel vs. Transport mode
- ❑ Security association (SA)
 - ❑ Security parameter index (SPI)
 - ❑ Security policy database (SPD)
 - ❑ SA database (SAD)
- ❑ Authentication header (AH)
- ❑ Encapsulating security payload (ESP)
- ❑ Practical issues w/ NAT

Transport Mode vs. Tunnel Mode

- ❑ Transport mode: host -> host
- ❑ Tunnel mode: host->gateway or gateway->gateway

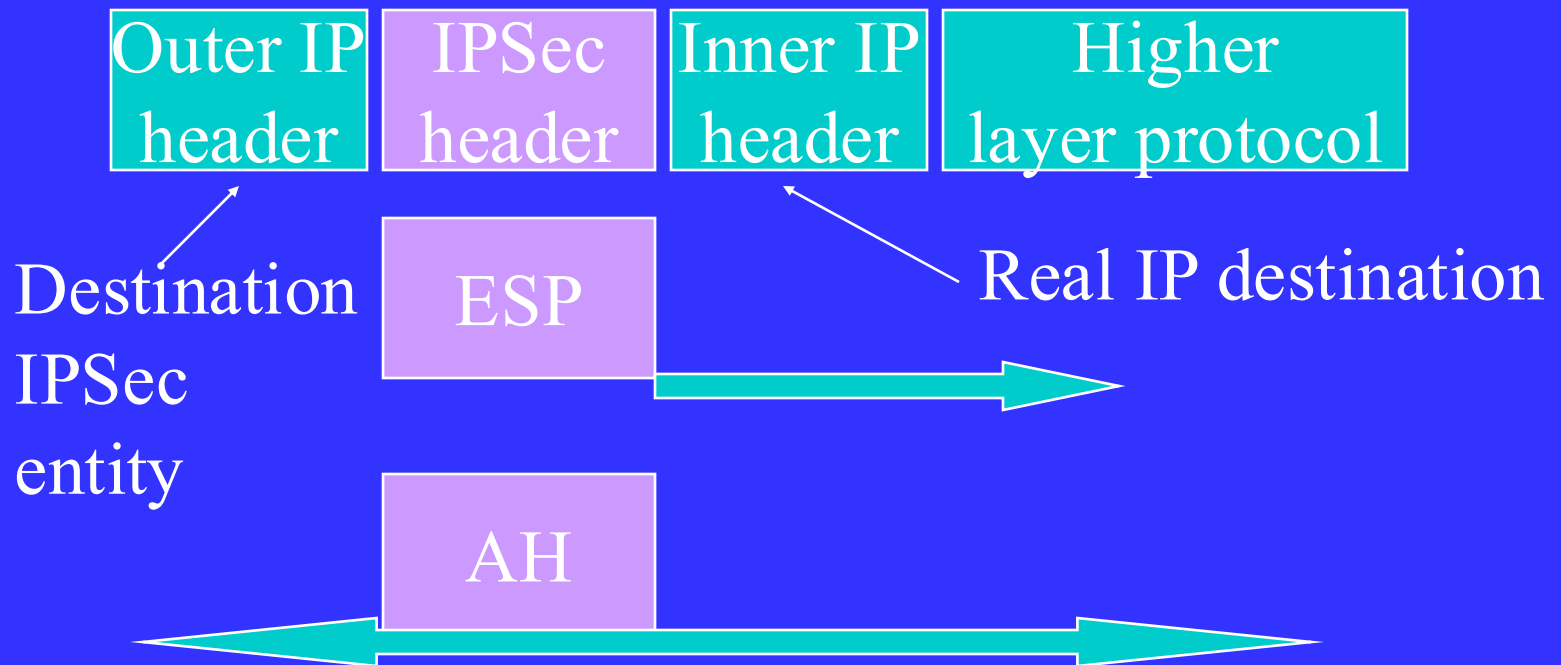


Transport Mode



- ❑ ESP protects higher layer payload only
- ❑ AH can protect IP headers as well as higher layer payload

Tunnel Mode



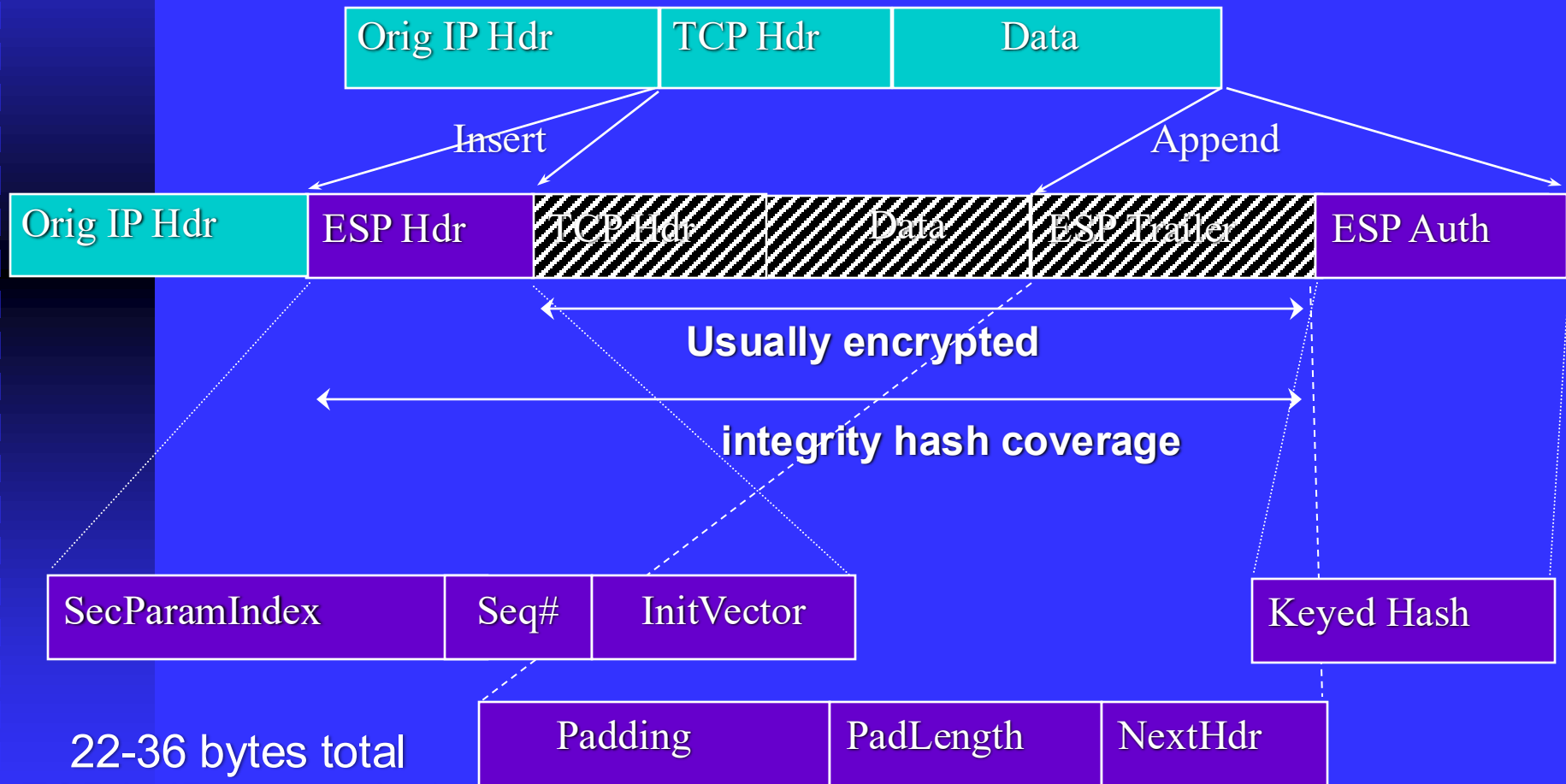
- ❑ ESP applies only to the tunneled packet
- ❑ AH can be applied to portions of the outer header

IPSec In Depth

Encapsulated Security Payload (ESP)

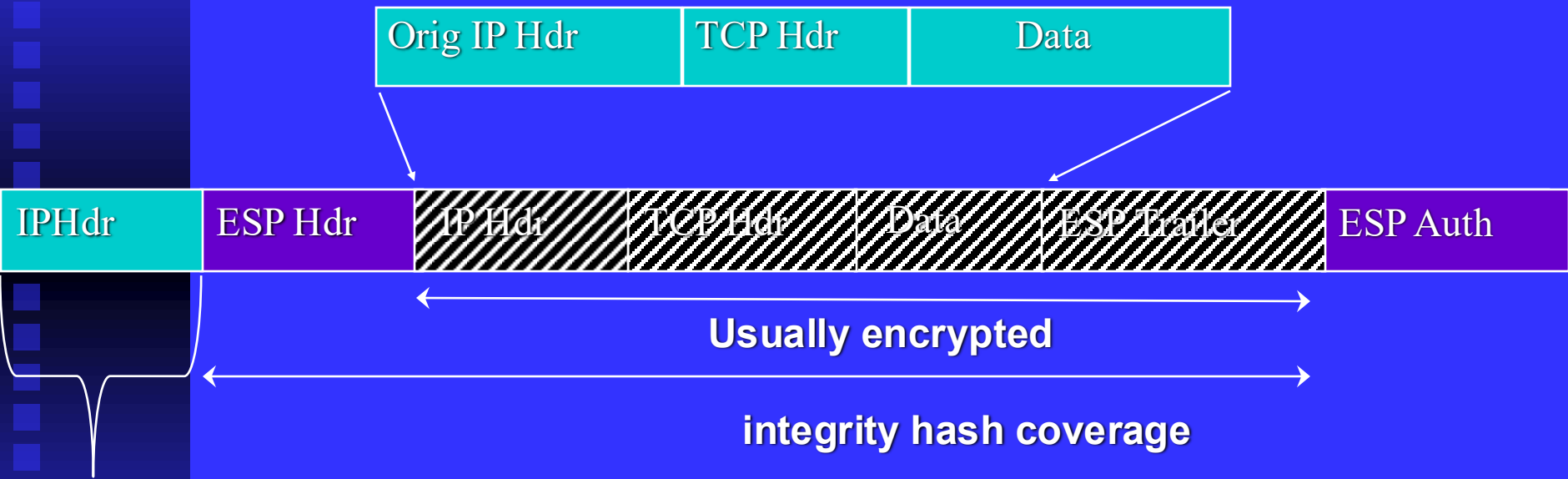
- ❑ Must encrypt and/or authenticate in each packet
- ❑ Encryption occurs before authentication
- ❑ Authentication is applied to data in the IPSec header as well as the data contained as payload

IPSec Encapsulating Security Payload (ESP) in Transport Mode



22-36 bytes total
ESP is IP protocol 50

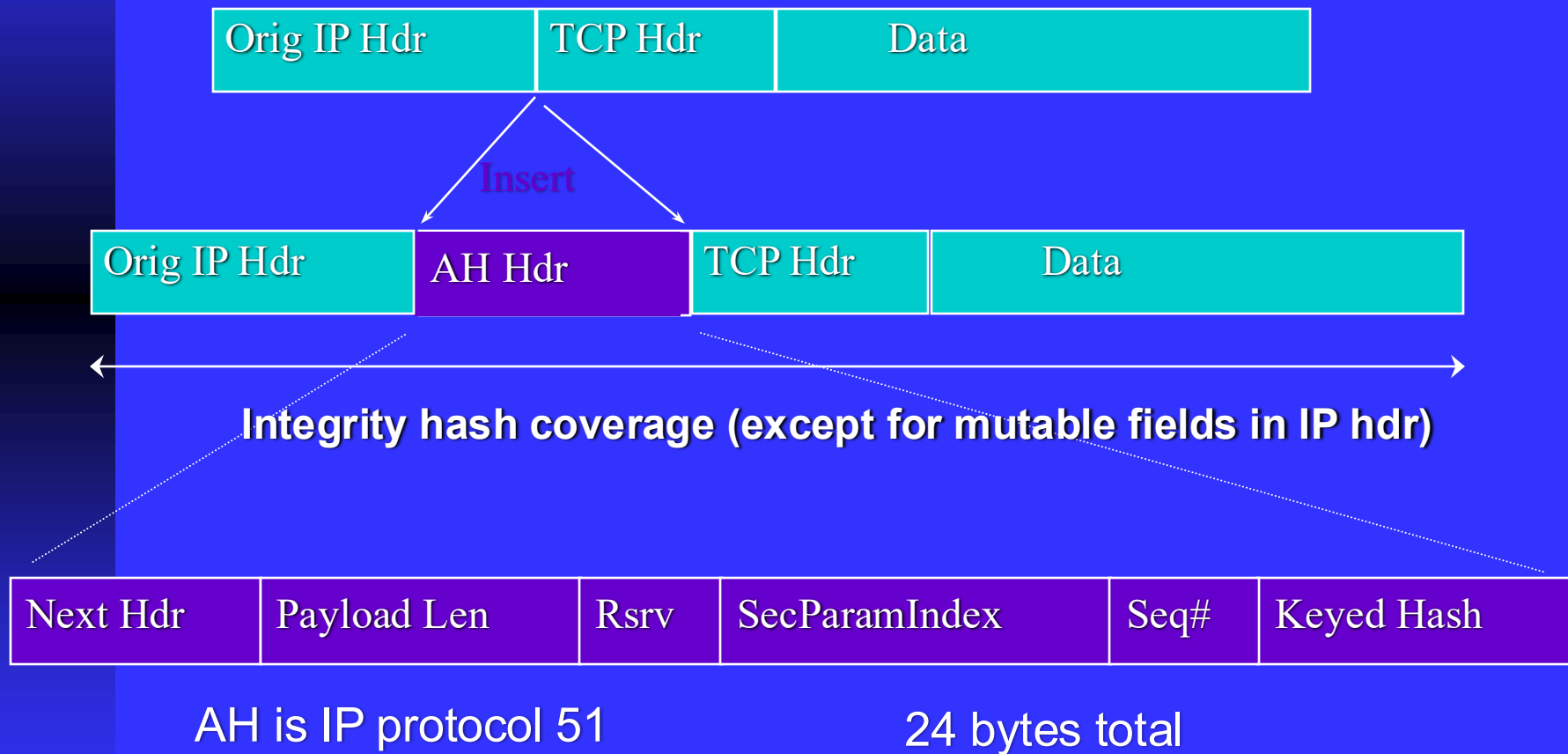
IPSec ESP Tunnel Mode



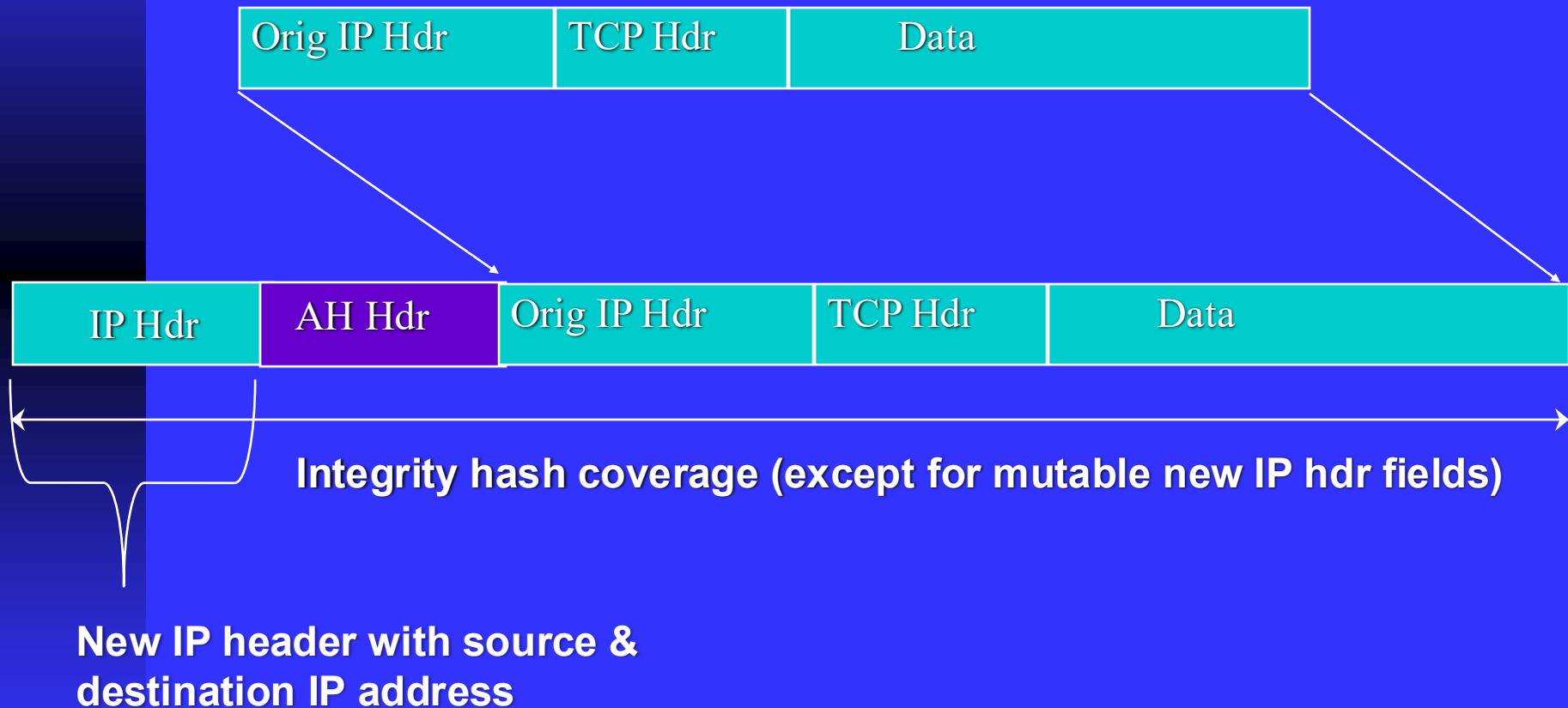
Authentication Header (AH)

- ❑ Authentication is applied to the entire packet, with the mutable fields in the IP header zeroed out
- ❑ If both ESP and AH are applied to a packet, AH follows ESP

IPSec Authentication Header (AH) in Transport Mode



IPSec AH Tunnel Mode



Internet Key Exchange (IKE)

❑ Phase I

- ❑ Establish a secure channel (ISAKMP SA)
- ❑ Authenticate computer identity

❑ Phase II

- ❑ Establishes a secure channel between computers intended for the transmission of data (IPSec SA)

Main Mode

- ❑ Main mode negotiates an ISAKMP SA which will be used to create IPSec SAs
- ❑ Three steps
 - ❑ SA negotiation
 - ❑ Diffie-Hellman and nonce exchange
 - ❑ Authentication

Main Mode (Kerberos)



Initiator



Responder

Header, SA Proposals



Header, Selected SA Proposal



Header, D-H Key Exchange, Nonce_i,
Kerberos Token_i



Header, D-H Key Exchange, Nonce_r,
Kerberos Token_r



Encrypted

Header, Id_i, Hash_i



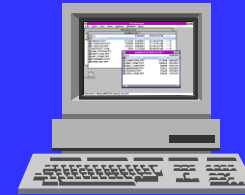
Header, Id_r, Hash_r



Main Mode (Certificate)



Initiator



Responder

Header, SA Proposals →

← Header, Selected SA Proposal

Header, D-H Key Exchange, Nonce_i →

← Header, D-H Key Exchange,
Nonce_r, Certificate Request

Encrypted

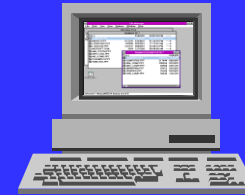
Header, Id_i, Certificate_i, Signature_i,
Certificate Request →

← Header, Id_r, Certificate_r,
Signature_r

Main Mode (Pre-shared Key)



Initiator



Responder

Header, SA Proposals →

← Header, Selected SA Proposal

Header, D-H Key Exchange, Nonce_i →

← Header, D-H Key Exchange, Nonce_r

Encrypted

Header, Id_i, Hash_i →

← Header, Id_r, Hash_r

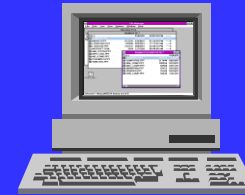
Quick Mode

- ❑ All traffic is encrypted using the ISAKMP Security Association
- ❑ Each quick mode negotiation results in two IPSec Security Associations (one inbound, one outbound)

Quick Mode Negotiation



Initiator



Responder

Encrypted

Header, IPSec Proposed SA →

← Header, IPSec Selected SA

Header, Hash →

← Header, Connected Notification

Architecture & Concepts

- ❑ Tunnel vs. Transport mode
- ❑ **Security association (SA)**
 - ❑ Security parameter index (SPI)
 - ❑ Security policy database (SPD)
 - ❑ SA database (SAD)
- ❑ Authentication header (AH)
- ❑ Encapsulating security payload (ESP)
- ❑ Practical Issues w/ NAT

Security Association - SA

- ❑ Have a database of Security Associations
- ❑ Determine IPSec processing for senders
- ❑ Determine IPSec decoding for destination
- ❑ SAs are not fixed! Generated and customized per traffic flows

Security Parameters Index - SPI

- ❑ Can be up to 32 bits large
- ❑ The SPI allows the destination to select the correct SA under which the received packet will be processed
 - ❑ According to the agreement with the sender
 - ❑ The SPI is sent with the packet by the sender
- ❑ SPI + Dest IP address + IPSec Protocol (AH or ESP) uniquely identifies a SA

SA Database - SAD

- ❑ Holds parameters for each SA
 - ❑ Lifetime of this SA
 - ❑ AH and ESP information
 - ❑ Tunnel or transport mode
- ❑ Every host or gateway participating in IPSec has their own SA database

Security Policy Database - SPD

- ❑ What traffic to protect?
- ❑ Policy entries define which SA or SA bundles to use on IP traffic
- ❑ Each host or gateway has their own SPD
- ❑ Index into SPD by Selector fields
 - ❑ Dest IP, Source IP, IPSec Protocol, Transport Protocol, Source & Dest Ports, ...

Security Policy Database - SPD

- ❑ What traffic to protect?
- ❑ Policy entries define which SA or SA bundles to use on IP traffic
- ❑ Each host or gateway has their own SPD
- ❑ Index into SPD by Selector fields
 - ❑ Dest IP, Source IP, IPSec Protocol, Transport Protocol, Source & Dest Ports, ...

SPD Entry Actions

- ❑ Discard

- ❑ Do not let in or out

- ❑ Bypass

- ❑ Outbound: do not apply IPSec
 - ❑ Inbound: do not expect IPSec

- ❑ Protect – will point to an SA or SA bundle

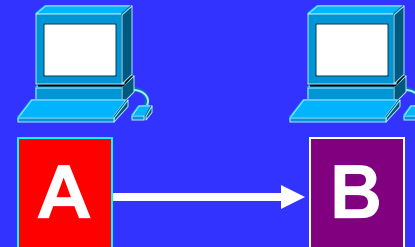
- ❑ Outbound: apply security
 - ❑ Inbound: check that security must have been applied

SPD Protect Action

- ❑ If the SA does not exist...
 - ❑ Outbound processing: use IKE to generate SA dynamically
 - ❑ Inbound processing: drop packet

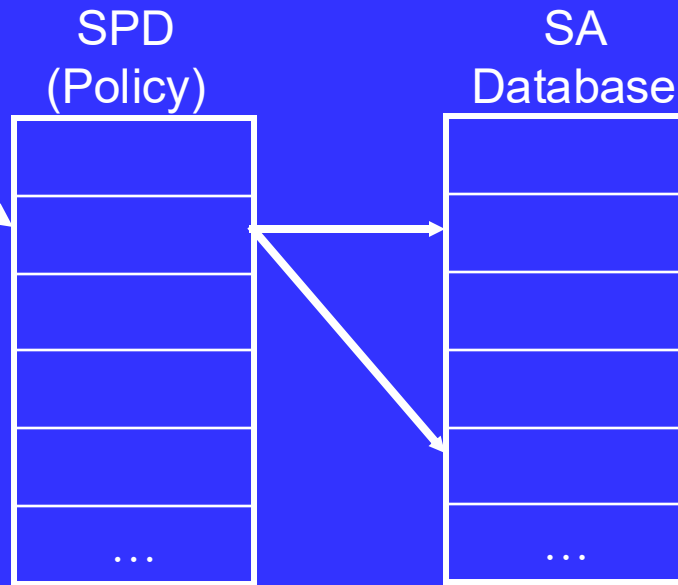
Outbound Processing

Outbound packet (on A)



IP Packet

*Is it for IPSec?
If so, which policy
entry to select?*



*Determine the SA
and its SPI*

IPSec processing

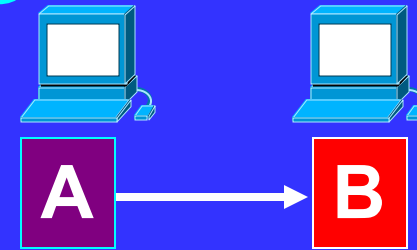
**SPI & IPSec
Packet**



Send to B

Inbound Processing

Inbound packet (on B)

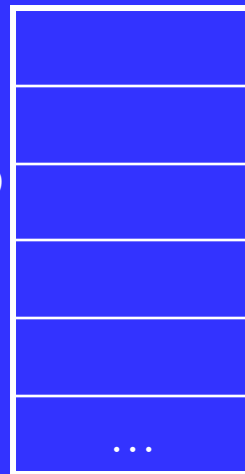


From A

SPI & Packet

SA Database

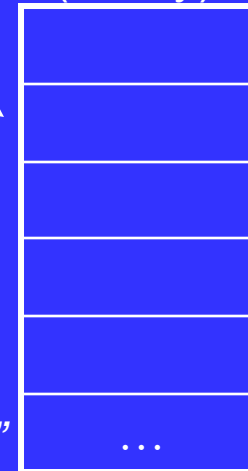
*Use SPI to
index the SAD*



"un-process"

SPD
(Policy)

*Was packet properly
secured?*



Original IP Packet

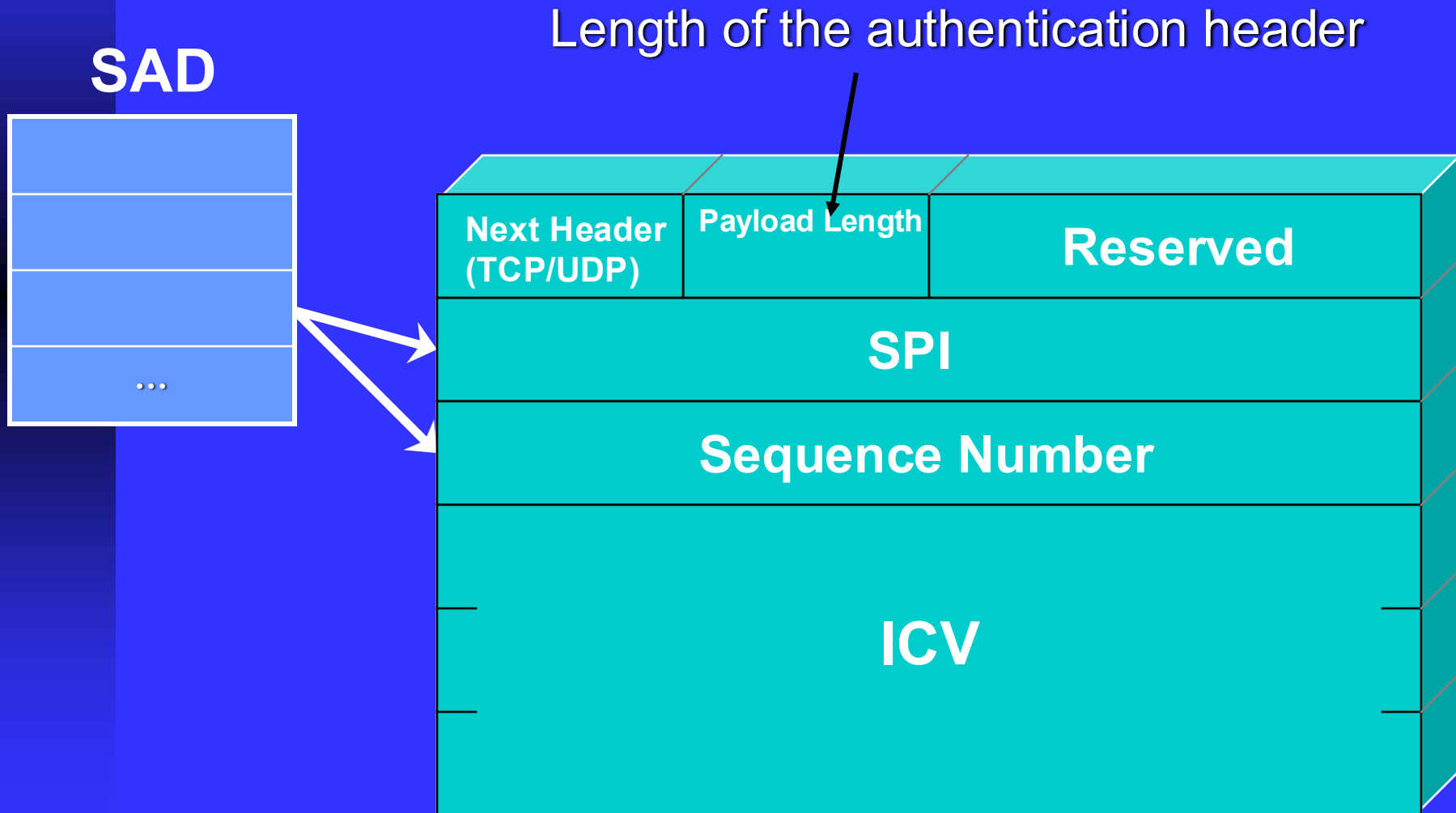
Architecture & Concepts

- ❑ Tunnel vs. Transport mode
- ❑ Security association (SA)
 - ❑ Security parameter index (SPI)
 - ❑ Security policy database (SPD)
 - ❑ SA database (SAD)
- ❑ Authentication header (AH)
- ❑ Encapsulating security payload (ESP)
- ❑ Practical Issues w/ NAT

Authenticated Header

- ❑ Data integrity
 - ❑ Entire packet has not been tampered with
- ❑ Authentication
 - ❑ Can “trust” IP address source
- ❑ Anti-replay feature
- ❑ Integrity check value

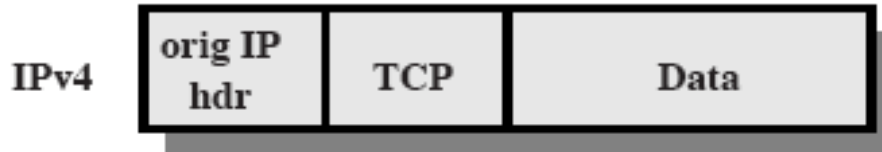
IPSec Authenticated Header



Integrity Check Value - ICV

- ❑ Keyed Message authentication code (MAC) calculated over
 - ❑ IP header field that do not change or are predictable
 - ❑ Source IP address, destination IP, header length, etc.
 - ❑ Prevent spoofing
 - ❑ Mutable fields excluded: e.g., time-to-live (TTL), IP header checksum, etc.
 - ❑ IPSec protocol header except the ICV value field
 - ❑ Upper-level data
- ❑ Code may be truncated to first 96 bits

AH: Tunnel and Transport Mode



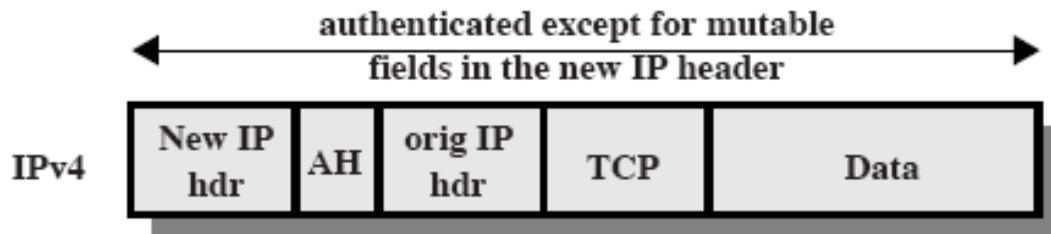
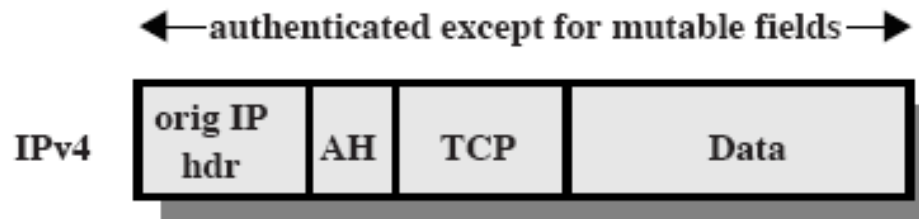
❑ Original

❑ Transport Mode

❑ Cover most of the original packet

❑ Tunnel Mode

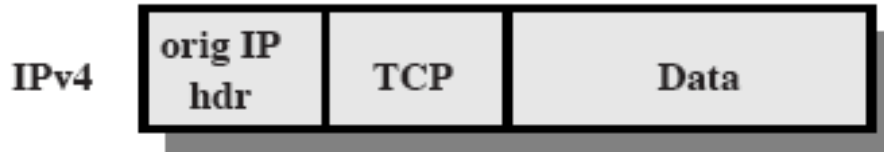
❑ Cover entire original packet



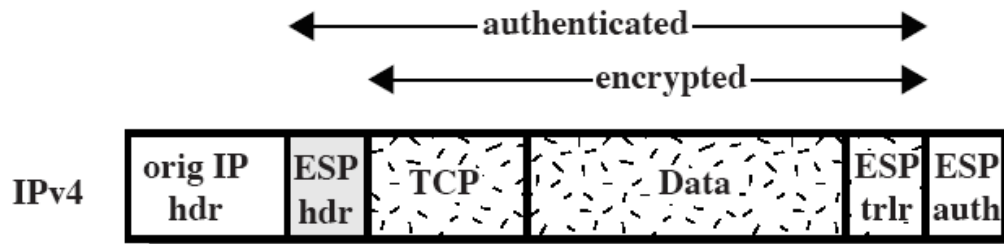
Encapsulating Security Payload (ESP)

- ❑ Provide message content confidentiality
- ❑ Provide limited traffic flow confidentiality
- ❑ Can optionally provide the same authentication services as AH
- ❑ Supports range of ciphers, modes, padding
 - ❑ Incl. DES, Triple-DES, RC5, IDEA, CAST etc
 - ❑ Pad to meet blocksize, for traffic flow

ESP: Tunnel and Transport Mode



❑ Original

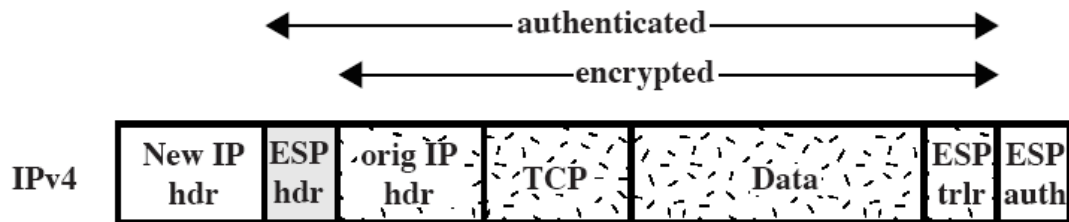


❑ Transport Mode

❑ Good for host to host traffic

❑ Tunnel Mode

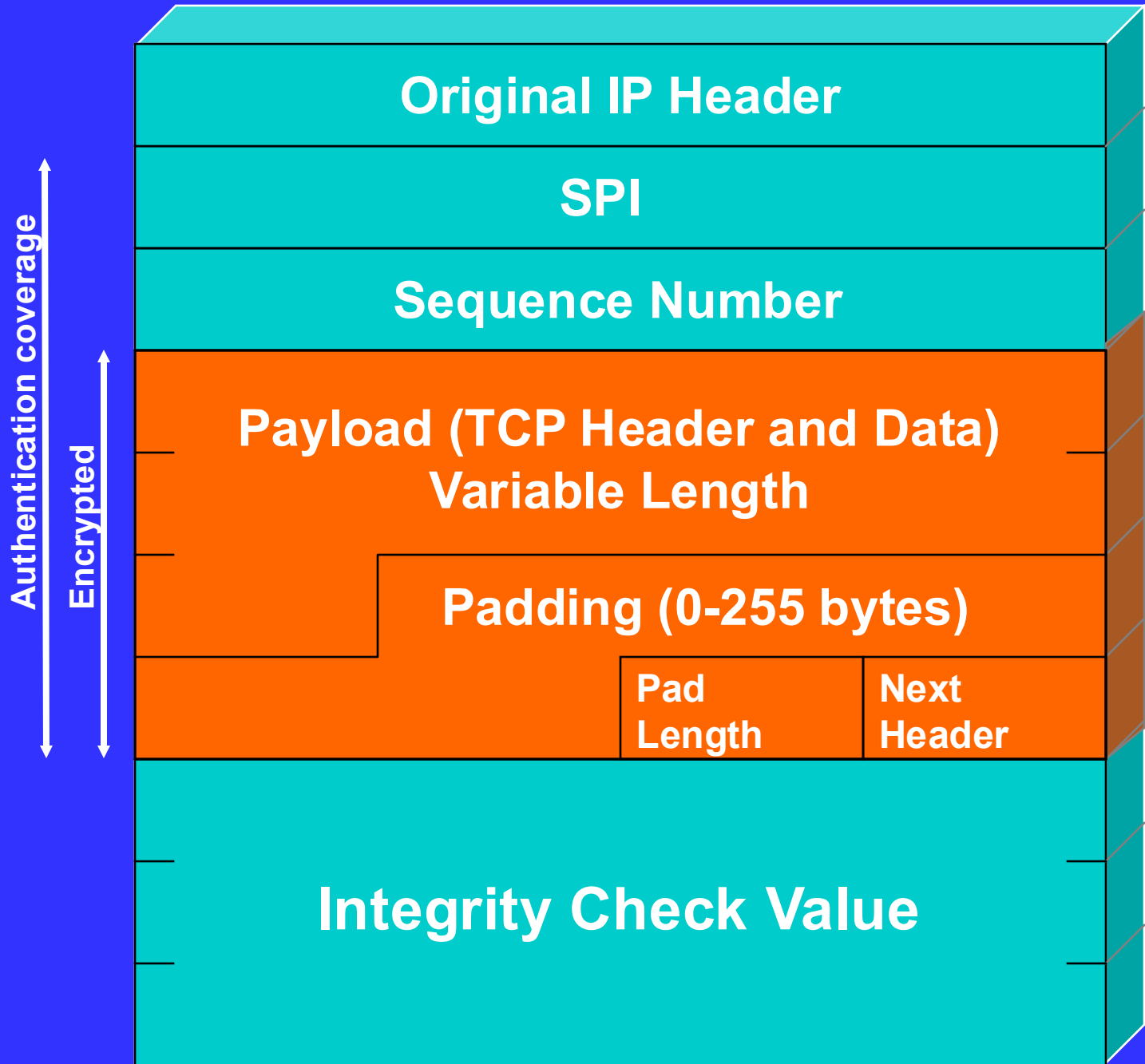
❑ Good for VPNs, gateway to gateway security



Outbound Packet Processing

- ❑ Form ESP header
 - ❑ Security parameter index (SPI)
 - ❑ Sequence number
- ❑ Pad as necessary
- ❑ Encrypt result [payload, padding, pad length, next header]
- ❑ Apply authentication (optional)
 - ❑ Allow rapid detection of replayed/bogus packets
 - ❑ Integrity Check Value (ICV) includes whole ESP packet minus *authentication data* field

ESP Transport Example



Inbound Packet Processing...

- ❑ Sequence number checking
 - ❑ Duplicates are rejected!
- ❑ Packet decryption
 - ❑ Decrypt quantity [ESP payload,padding,pad length,next header] per SA specification
 - ❑ Processing (stripping) padding per encryption algorithm
 - ❑ Reconstruct the original IP datagram
- ❑ Authentication verification (optional)
 - ❑ Allow potential parallel processing - decryption & verifying authentication code

Architecture & Concepts

- ❑ Tunnel vs. Transport mode
- ❑ Security association (SA)
 - ❑ Security parameter index (SPI)
 - ❑ Security policy database (SPD)
 - ❑ SA database (SAD)
- ❑ Authentication header (AH)
- ❑ Encapsulating security payload (ESP)
- ❑ **Practical Issues w/ NAT**

IPSec Pros

- ❑ Hides the identity of your network
- ❑ Provides secure channel: confidentiality, authenticity, and integrity
- ❑ Connects sites (e.g., branch offices) with a cost-effective secure network compared with leased lines
- ❑ Allows user to work from home and mobile hosts

IPSec Cons

- ❑ A single failure in the path disconnect the entire network. Also cause performance bottlenecks.
- ❑ Incompatible with NAT/PAT depending on the architecture
- ❑ Tunneled traffic is undetected by IDS
- ❑ VPN gateways might be compromised which leads to uncovering protected data

NATs

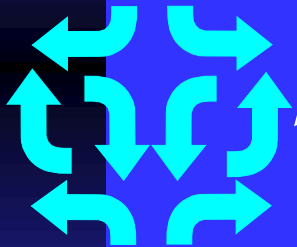
- ❑ Network address translation = local, LAN-specific address space translated to small number of globally routable IP addresses
- ❑ Motivation:
 - ❑ Scarce address space
 - ❑ Security: prevent unsolicited inbound requests
- ❑ Prevalence of NATs
 - ❑ Claim: 50% of broadband users are behind NATs
 - ❑ All Linksys/D-Link/Netgear home routers are NATs

NAT types

- ❑ All use net-10/8 (10.*.*.*) or 192.168/16
- ❑ Address translation
- ❑ Address-and-port translation (NAPT)
 - ❑ most common form today, still called NAT
 - ❑ one external (global) IP address
- ❑ Change IP header and TCP/UDP headers

NAT Example

IAP's Point of Presence

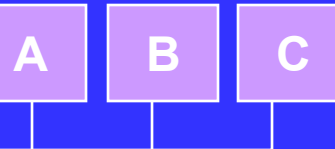


Messages sent between host B
to another host on the Internet
Host B original source socket:
192.168.0.101 port 1341
Host B translated socket:
68.40.162.3 port 5280

Router with NAT
External IP: 68.40.162.3
Internal IP: 192.168.0.0

Router assigns internal
IPs to hosts on LAN :

A:	192.168.0.100
B:	192.168.0.101
C:	192.168.0.102



Will IPSec Work with NAT ?

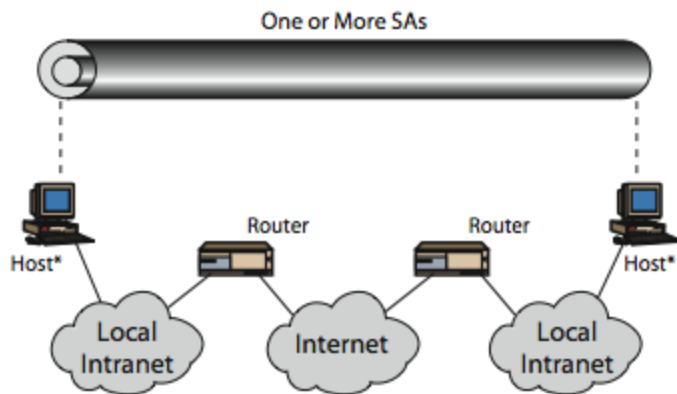
- ❑ Consider both AH and ESP protocols.
- ❑ Consider both transport and tunnel modes. For tunnel mode, consider the following two cases
 - ❑ Sender – NAT – IPSec Gateway 1 – IPSec Gateway 2 – Receiver
 - ❑ Sender – IPSec Gateway 1 – NAT – IPSec Gateway 2 – Receiver
- ❑ What about no port # translation?
- ❑ Practical solutions for NAT to work w/ IPSec
 - ❑ IPSec – NAC Compatibility Requirements: RFC 3715
 - ❑ UDP Encapsulation of IPsec ESP Packets: RFC 3948

Backup Slides

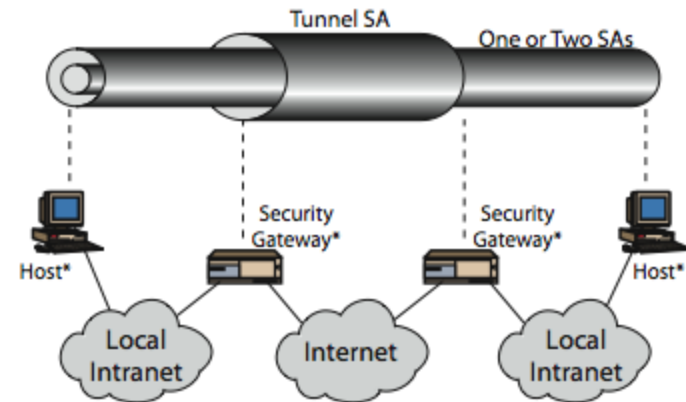
Combining Security Associations

- ❑ SA's can implement either AH or ESP
- ❑ to implement both need to combine SA's
 - ❑ form a security association bundle
 - ❑ may terminate at different or same endpoints
 - ❑ combined by
 - ❑ transport adjacency
 - ❑ iterated tunneling
- ❑ issue of authentication & encryption order

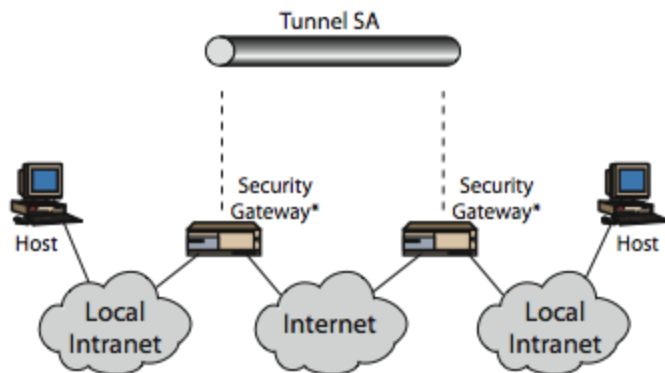
Combining Security Associations



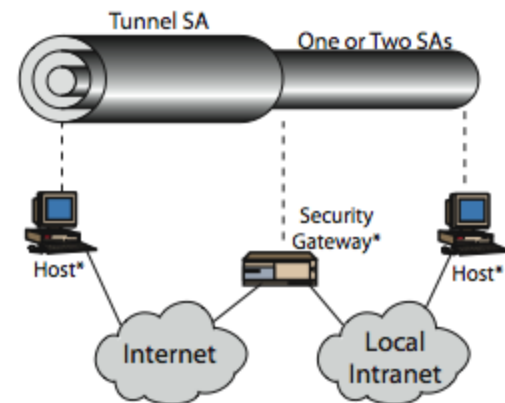
(a) Case 1



(c) Case 3



(b) Case 2



(d) Case 4

SA Bundle

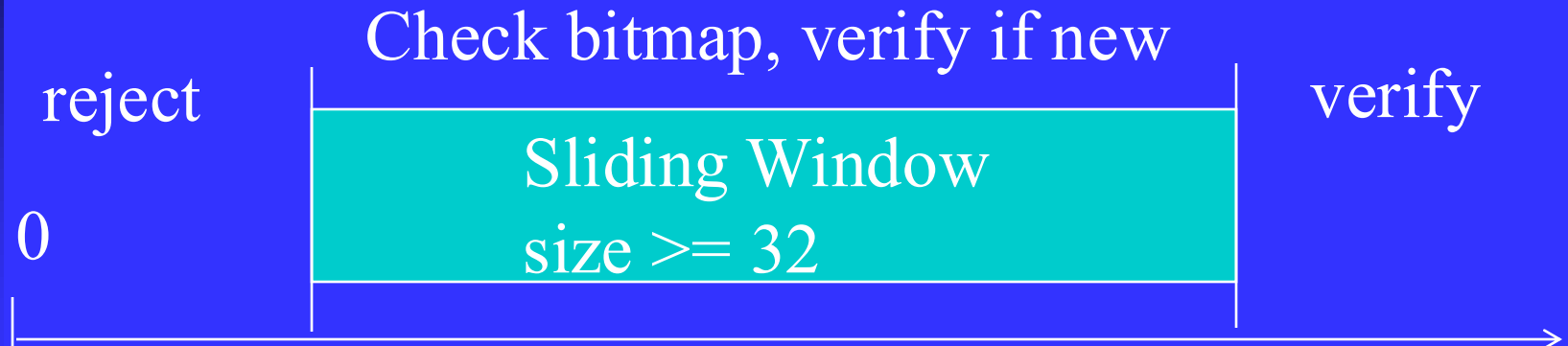
- ❑ More than 1 SA can apply to a packet
- ❑ Example: ESP does not authenticate new IP header. How to authenticate?
 - ❑ Use SA to apply ESP w/o authentication to original packet
 - ❑ Use 2nd SA to apply AH

Outbound Packet Processing...

- ❑ Integrity Check Value (ICV) calculation
 - ❑ ICV includes whole ESP packet minus *authentication data* field
 - ❑ Implicit padding of '0's between *next header* and *authentication data* is used to satisfy block size requirement for ICV algorithm

Inbound Packet Processing

- ❑ Sequence number checking
 - ❑ Anti-replay is used only if authentication is selected
 - ❑ Sequence number should be the first ESP check on a packet upon looking up an SA
 - ❑ Duplicates are rejected!



Anti-replay Feature

- ❑ Optional
- ❑ Information to enforce held in SA entry
- ❑ Sequence number counter - 32 bit for outgoing IPSec packets
- ❑ Anti-replay window
 - ❑ 32-bit
 - ❑ Bit-map for detecting replayed packets

Anti-replay Sliding Window

- ❑ Window should not be advanced until the packet has been authenticated
- ❑ Without authentication, malicious packets with large sequence numbers can advance window unnecessarily
 - ❑ Valid packets would be dropped!

ESP Processing - Header Location...

IPv4

New IP hdr	ESP hdr	Orig IP hdr	TCP	Data	ESP trailer	ESP Auth
---------------	------------	----------------	-----	------	----------------	-------------

IPv6

New IP hdr	New ext hdr	ESP hdr	Orig IP hdr	Orig ext hdr	TCP	Data	ESP trailer	ESP Auth
---------------	----------------	------------	----------------	-----------------	-----	------	----------------	-------------

❑ Tunnel mode IPv4 and IPv6

Key Management

- ❑ Handles key generation & distribution
- ❑ Typically need 2 pairs of keys
 - ❑ 2 per direction for AH & ESP
- ❑ Manual key management
 - ❑ Sysadmin manually configures every system
- ❑ Automated key management
 - ❑ Automated system for on demand creation of keys for SA's in large systems